SECURITY & CONFIGURATION MANAGEMENT (12-FACTOR APP)

สถานการณ์ที่ 4: ผลกระทบจากการ Hardcode และแนวทางการจัดเก็บ API Key / URL

> **โจทย์และสถานการณ์ที่ 4**
>
> หากคุณพบว่ามีคนฝัง API Key หรือ URL ของ 3rd-party ไว้ใน Source Code ตรงๆ (Hardcode) คุณจะอธิบายผลกระทบที่จะตามมาให้เขาฟังอย่างไร และจะให้เขาแก้วิธีเก็บ Key อย่างไรให้ถูกต้อง?

คำตอบและแนวทางการปฏิบัติ

อธิบายให้เห็นภาพความเสียหายจริง ถ้าหลุดขึ้น Git เท่ากับหลุดถาวร เสี่ยงโดนสวมรอยใช้งานจนเกิดค่าใช้จ่ายมหาศาล หรือข้อมูลรั่วไหล ฝัง URL ทำให้แยก Environment (Dev/UAT/Prod) ไม่ได้ และถ้า 3rd-party เปลี่ยน URL เราต้องแก้โค้ด Build ใหม่และ Deploy ใหม่ทั้งหมด แก้โดยแยก **Configuration ออกจาก Code (ตามหลัก 12-Factor App)** โดยใช้ **Environment Variables** สำหรับ URL และใช้ **Secret Manager** สำหรับ API Key

สรุปผลกระทบจากการฝังค่าไว้ใน Source Code (Hardcode)

- **ด้านความปลอดภัยและค่าใช้จ่าย (กรณีฝัง API Key):** หากหลุดขึ้น Git เท่ากับหลุดถาวร (เพราะมีประวัติอยู่ใน Commit History) เสี่ยงต่อการโดนสวมรอยนำ Key ไปใช้งานจนเกิดค่าใช้จ่ายมหาศาล หรือเกิดเหตุข้อมูลรั่วไหล
- **ด้านการจัดการระบบและการ Deploy (กรณีฝัง 3rd-party URL):** ทำให้ไม่สามารถแยกสภาพแวดล้อมการทำงาน (Environment: Dev / UAT / Prod) ออกจากกันได้ และหากฝั่ง 3rd-party มีการเปลี่ยน URL จะต้องกลับมาแก้โค้ด สั่ง Build ใหม่ และ Deploy ใหม่ทั้งหมด

แนวทางการจัดเก็บและเรียกใช้งานอย่างถูกต้อง (ตามหลัก 12-Factor App)

ประเภทข้อมูล	เครื่องมือที่ใช้เก็บ	การเรียกใช้ในโค้ด / ตอนรันระบบ
3rd-Party URL (ไม่เป็นความลับ)	ไฟล์ `.env` หรือไฟล์ Config ประจำ Environment	เรียกผ่าน Environment Variable เช่น `process.env.THIRD_PARTY_API_URL`
API Key / Secret (ความลับสูงสุด)	• เครื่องตัวเอง (Local): เก็บในไฟล์ `.env` ที่อยู่ใน `.gitignore` เท่านั้น • ระบบจริง (Server/Cloud): เก็บใน **Secret Manager**	ดึงผ่าน Secret Manager SDK หรือฉีดเข้า Environment Variable ตอนรัน Container